TP Cybersécurité — Compte Rendu

Analyse d'une attaque Man-In-The-Middle (MITM) en environnement virtualisé

Firdaous Amadou · BTS SIO SISR · EFREI Paris · 25 février 2026

Objectifs du TP

- Comprendre le fonctionnement d'un réseau local (ARP, IP, routage)
- Expliquer le rôle de l'IP forwarding sous Linux
- Décrire le principe d'une attaque Man-In-The-Middle
- Étudier le fonctionnement d'Ettercap
- Expliquer pourquoi HTTP est vulnérable et pourquoi HTTPS protège

Architecture déployée

Machine	Rôle	Détail
Serveur	Site web HTTP	Apache + PHP — page de connexion vulnérable
Client	Poste de travail	Interface graphique — navigateur Firefox
Attaquant	Intermédiaire réseau	IP forwarding + Ettercap (ARP poisoning)

Tâches réalisées

Toutes les tâches ont été complétées avec succès, comme en témoignent les validations ci-dessous :

Tableau de bord des tâches — toutes validées le 25/02/2026

1. Interception des identifiants en HTTP

L'attaque MITM a été réalisée avec Ettercap via ARP poisoning. En se positionnant entre le client et le serveur, la machine attaquante a intercepté les identifiants transmis en clair sur le réseau HTTP.

Identifiants interceptés :

```
username=alice&password=test123
```

Capture d'écran — interception des identifiants (HTTP) :

```
Host: 192.168.56.10
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 31
Origin: http://192.168.56.10
Connection: keep-alive
Referer: http://192.168.56.10/
Upgrade-Insecure-Requests: 1
Priority: u=0, i

username=alice&password=test123
```

Capture tcpdump/Ettercap — identifiants visibles en clair dans la requête HTTP POST

2. Sécurisation du serveur avec HTTPS

Après avoir démontré la vulnérabilité HTTP, le serveur a été sécurisé avec HTTPS via un certificat auto-signé. Le trafic est désormais chiffré — Ettercap ne peut plus lire les données en transit.

Capture d'écran — trafic HTTPS chiffré :

```
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on enp0s8, link-type EN10MB (Ethernet), snapshot length 262144 bytes
20:20:02.598230 IP 192.168.56.20.51756 > 192.168.56.10.https: Flags [S], seq 2580034148, win 64240, options [mss 1460,sackOK,TS val 1735978209 ecr 0,nop,wsc
ale 7], length 0
E..<e.@.@..K.8...8
.,....2d........o1........
gx......................
20:20:02.598360 IP 192.168.56.10.https > 192.168.56.20.51756: Flags [S.], seq 3559236538, ack 2580034149, win 65160, options [mss 1460,sackOK,TS val 2480046
013 ecr 1735978209,nop,wscale 7], length 0
E..<..@.@.IM..8
..8....,%....2e..............
....gx..................
20:20:02.599978 IP 192.168.56.20.51756 > 192.168.56.10.https: Flags [.], ack 1, win 502, options [nop,nop,TS val 1735978211 ecr 2480046013], length 0
E..4e.@.@..R..8...8
.,....2e.%......u....
gx......
20:20:02.620453 IP 192.168.56.20.51756 > 192.168.56.10.https: Flags [P.], seq 1:2016, ack 1, win 502, options [nop,nop,TS val 1735978230 ecr 2480046013], le
ngth 2015
E...e.@.@..r..8...8
.,....2e.%......t.....
gx......................1....`.....i}..Tp]      "%...G.. ?..I......'...t.Z...X...........".......+./.....,.0.
.         .........../.5...k.......
..........................h2.http/1.1.........".
...............3./.-......=.X...1.........n.9+0r`B.`...8..".:.$".aR.|.2}................<.[%e0._.^..y....r9.9......Z........r.V.0j...U;.v.a.UwI.....@>.?g..
s.
....!.;1..\...C..Y.Y"....n$%.G.k,...DH.        .B8.k.R".<.Z.$.94..W...
.\....ym>....<:.3.@;.knyy........W...........XH..3.....0.......cF..10..8.?.c.n.Pq.5..q..(...M..Q...EK|.Z...h.a.
T....+..(FXW...A.Z;......Y3......(.B..J.:T.&.D...{.9..m+&.....`^.F@..K.h_&6.#.2"....YGS.O2ka.\..nq...R.D
%&4VR....P.........W...".....Y...  .....Y......6p.T.[}.*.d.s...F..k.B_....{a.Fm$..k.6j.....Q4.[n..B..{.W?...  .      H.t.....e.)..B.4.N9$...(*p...+t5I....AU.
qq.....".$...z..&R [..l...[.#|.7.X.f....z..x}.e.j.      ...AK."}                  .g.....~}.....k.../.        .i`..C.&A.....pP..98. ....s..U?#W....Qb....O:L..2N.\,..A.H.X
.,K.E.d...o.......<...1.Z..~GG..!....8......1O...k7+.I.P..............FeA....D0M,O.  .@....o
..x...Q4..q".:Sf.}...rt.,.../J.26cF....,.Ci.g.T.PC..JjR...K......?K.`.;z...R..a.Yz<*....i..{....A..:.[`A.a..,z..EF.c.....H$..^>.w.qPe..2.......kk.]..9~*.#W..
.,........c...9<.......;.097...q,PBA[.....we.....G..J...k..s.&...`c.p.2./.P..{...k.N.........C"=*,K. .....{x..s.QO&.@..G.Y.`.)4...<........p^......*....G
        .7E.7.c.B...V~.)u.....K.pF..l...d....  |...%(.z\.~^.X.S.W.t%..g.....k.98.v.P.Q.lvQ..H....l.].t.@.j.... .k.98.v.P.Q.lvQ..H....l.].t.@.j....A....i.B
....i=...g......s....e.N..xu..j.{.2-.....~...
..P.T..Q.D..+.......................................-........@...............Y.....8. ..?...h....<..t..t.Y....|.....&../..rh~..Z.....b..B;.......O........}*..&
.....'.....<.6T...  g..F.........  |.Z.1......B.T.U.JO........^)x 8  ...W.f..B.....F..~....NQ....xD.[......E$.l.M.s......z{.G.,o>.C%.>S.n2.R#.y...(+.j.l
d.....-.qo.Jk..b8:...g-.m...).X.b.....lv..m...Z..uX....T..\z.~.OI...^t..h.....,...E._.54;{......w~.]...&.x..        .).K.&. ...Z..X.....H...m.F%.Sf...G.\.s.
.....! !.9!.=.X.#.f...bad;...S.S.S...]x
20:20:02.620519 IP 192.168.56.10.https > 192.168.56.20.51756: Flags [.], ack 2016, win 496, options [nop,nop,TS val 2480046036 ecr 1735978230], length 0
```

Capture tcpdump — trafic chiffré TLS, les identifiants ne sont plus lisibles

BONUS — Découverte des vrais identifiants (base64)

En accédant au code source PHP du serveur, des identifiants encodés en base64 ont été découverts dans les fichiers de configuration. Décodage effectué en CLI :

Accès au répertoire web :

```
cd /var/www/html
```

Recherche des chaînes base64 :

```
grep -Rni "base64" .
```

Chaînes trouvées dans le code :

```
$USER_B64 = 'YWxpY2U='
$PASS_B64 = 'ZGVtbzEyMw=='
```

Décodage username :

```
echo 'YWxpY2U=' | base64 -d   ->  alice
```

Décodage password :

```
echo 'ZGVtbzEyMw==' | base64 -d   ->  demo123
```

```
Vrai username : alice

Vrai password : demo123
```

Conclusion

Ce TP a démontré concrètement les risques du protocole HTTP en clair. Une attaque MITM avec Ettercap permet à un attaquant positionné sur le même réseau d'intercepter en quelques secondes des identifiants transmis sans chiffrement. Le passage à HTTPS rend cette interception impossible — le trafic chiffré par TLS n'est plus lisible même si l'attaquant intercepte les paquets. La découverte des identifiants base64 dans le code PHP illustre également l'importance de ne jamais stocker des secrets en clair ou en encodage réversible dans le code source.